

Control implementation matrix (NIST SP 800-53 rev5)

An **index**, not a narrative. Every row points at the template resource that implements a control and the document section that explains it — the implementation summary is one or two lines, deliberately, because the real explanation already exists elsewhere in this package and duplicating it would create two things to keep in sync.

Scope note: this deployment is a **client-configurable template**, not a fielded system. Rows describe what the templates and scripts do; they do not assert an organizational control baseline, a tailoring decision, or an inheritance agreement — those are the deploying organization's to make. Where a control is only partly addressed in-repo, the row says **Partial** and names where the residual is tracked. When code and this table disagree, the code wins and this file needs a PR.

Contents:

1. [How to read this matrix](#)
2. [Inheritance and shared responsibility](#)
3. [AC — Access Control](#)
4. [AU — Audit and Accountability](#)
5. [CA — Assessment, Authorization, and Monitoring](#)
6. [CM — Configuration Management](#)
7. [CP — Contingency Planning](#)
8. [IA — Identification and Authentication](#)
9. [SC — System and Communications Protection](#)
10. [SI — System and Information Integrity](#)
11. [SA / SR — Acquisition and Supply Chain](#)
12. [Families not addressed by this repository](#)
13. [Deviations and accepted risks, collected](#)

1. How to read this matrix

Each row has four columns plus a status:

- **Control** — the SP 800-53 rev5 identifier. Control *enhancements* are cited only where the repo demonstrably implements the enhancement.
- **Status** — one of:
 - **Implemented** — the templates/scripts implement it and the claim was verified against the file cited.
 - **Partial** — implemented in part; the residual is a documentation gap (`ato-package-gaps.md`) or an open finding (`poam.md`).
 - **Inherited** — provided by AWS GovCloud, the landing zone, Okta, or Zscaler; this system consumes it (see §2).

- **Deviation** — a deliberate, recorded departure. Rationale lives in the accepted-risk section (§2) of `security-assessment-2026-07.md`.
- **Implementation summary** — one or two lines, no more.
- **Where implemented** — file and resource/parameter.
- **Where documented** — doc and section.

Paths are repo-relative. `<prefix>` is the deployment's `NAME_PREFIX`. `poam.md` and `security-assessment-2026-07.md` are the companion documents in this directory; `ato-package-gaps.md` is the documentation-gap register.

2. Inheritance and shared responsibility

Rows marked **Inherited** depend on one of these providers. The repo does not hold the agreements or evidence for them; a full external-dependency register is an open documentation gap (`ato-package-gaps.md` , GAP-10).

Provider	Boundary side	What this system relies on it for
AWS GovCloud (US) <code>us-gov-west-1</code>	Below the boundary (IaaS/PaaS)	Physical/environmental, hypervisor, region-level compliance posture, KMS HSMs, Bedrock model hosting, service durability
AWS Landing Zone (org-operated)	Adjacent	Transit Gateway routing, central egress inspection, account guardrails/SCPs, log-archive account (if used)
Okta (org tenant)	External SaaS	User identity lifecycle, authentication strength (incl. MFA policy), group membership, session policy at the IdP
Zscaler (ZPA/ZIA)	Adjacent	Client-side reachability to the internal ALB, client-side web egress policy, the server-side egress ALLOW + inspection exemption for the Okta issuer
This system	Inside	Everything in §3–§11 below

Boundary and trust-zone description: `conops.md` §1.4; `architecture.md` §1. Organizational prerequisites: `conops.md` §8.2.

3. AC — Access Control

Control	Status	Implementation summary	Where implemented	Where documented
AC-2	Partial	Human identities are Okta-managed; the system defines only service/DB identities — a NOLOGIN owner role plus the alternating <code>gateway_app / gateway_app_clone</code> login pair, and an RDS master reserved for break-glass. Joiner/mover/leaver is Okta's, i.e. an org dependency.	<code>cloudformation/01-database.yaml</code> (<code>Database</code> , <code>DBParameterGroup</code>); <code>docker/db-admin/app.py</code> (bootstrap); <code>cloudformation/02-gateway.yaml</code> (<code>DbBootstrapFunction</code>)	<code>architecture.md</code> §4; <code>conops.md</code> §3, §8.2
AC-2(3)	Partial	Deprovisioning is bounded by token/session TTL, not by an immediate revoke: portal access persists up to <code>SessionTtlHours</code> (04, default 8 h, max 24 h), spend-admin capability up to the gateway token lifetime. No "revoke this user now" procedure exists in-repo.	<code>cloudformation/04-download-portal.yaml</code> (<code>SessionTtlHours</code>); <code>cloudformation/02-gateway.yaml</code> (<code>session: block</code> , <code>SessionTtlHours</code>)	<code>conops.md</code> §6.2; accepted risk A9 in <code>security-assessment-2026-07.md</code> §2; gaps: <code>ato-package-gaps.md</code> GAP-4, GAP-12
AC-3	Implemented	Three independent enforcement points: the gateway admits an authenticated Okta user in an approved email domain; the portal requires membership of <code>AccessGroup</code> ; Grafana maps Okta groups to roles strictly and denies unmapped users.	<code>cloudformation/02-gateway.yaml</code> (<code>allowed_email_domains ← AllowedEmailDomains</code>); <code>cloudformation/04-download-portal.yaml</code> (<code>AccessGroup</code>); <code>cloudformation/03-observability.yaml</code> (<code>GrafanaAdminGroup / GrafanaEditorGroup / GrafanaViewerGroup</code> , <code>GF_AUTH_GENERIC_OAUTH_ROLE_ATTRIBUTE_STRICT</code>)	<code>conops.md</code> §3.1, §3.5, §3.6; <code>architecture.md</code> §3
AC-3	Deviation	Okta group claims are not gateway access control — the <code>groups</code> scope is requested for per-group spend caps only. Gateway authorization reads as "authenticated Okta user in an approved email domain"; per-group policy is an available, unexercised extension.	<code>cloudformation/02-gateway.yaml</code> (<code>oidc: scopes</code> , <code>spend_limits</code> <code>rbac_group</code> scope)	<code>conops.md</code> §3.1; accepted risk A15 in <code>security-assessment-2026-07.md</code>
AC-4	Implemented	Flow is constrained at four layers: internal-only ALB, explicit security-group rule <i>pairs</i> with default egress suppressed, VPC interface-endpoint resource policies, and IAM. The complete rule graph is tabulated, not summarized.	<code>cloudformation/02-gateway.yaml</code> + 03 + 04 (all <code>AWS::EC2::SecurityGroup*</code> , <code>AWS::EC2::VPCEndpoint</code> <code>PolicyDocument</code> s)	<code>network-access-controls.md</code> §1–§3; <code>architecture.md</code> §7

Control	Status	Implementation summary	Where implemented	Where documented
AC-5	Partial	Separation exists in practice — break-glass RDS master vs. running app user, spend admin vs. platform operator, ECS execution role vs. task role — but there is no consolidated separation-of-duties statement or privileged-role inventory.	<code>cloudformation/02-gateway.yaml</code> (execution/task role split, repeated in 03/04)	<code>conops.md</code> §3; gap: <code>ato-package-gaps.md</code> GAP-12
AC-6	Implemented	Least privilege is structural: no task injects the RDS master secret; each execution role's <code>GetSecretValue</code> list matches exactly the secrets its own task definition injects; Bedrock IAM and endpoint policies enumerate the three configured model IDs and their derived foundation-model ARNs, never a wildcard family.	<code>cloudformation/01-database.yaml</code> ; <code>cloudformation/02-gateway.yaml</code> (<code>*ExecutionRole</code> , <code>*TaskRole</code> , <code>BedrockRuntimeEndpoint</code> policy)	<code>architecture.md</code> §4, §6; <code>network-access-controls.md</code> §3
AC-6(1)	Deviation	The portal task holds the read-only spend key (<code>SPEND_READ_KEY</code> , imported from 02's <code>\${NamePrefix}-spend-read-key-arn</code> export) so <code>/portal/me</code> can show a user their own caps and spend. The write key never reaches 04; the all-users admin table uses each admin's own device-flow bearer instead.	<code>cloudformation/02-gateway.yaml</code> (<code>SpendAdminReadKeySecret</code> , output <code>SpendReadKeySecretArn</code>); <code>cloudformation/04-download-portal.yaml</code> (container secret <code>SPEND_READ_KEY</code>)	<code>cost-controls.md</code> §3.4; accepted risk A10 in <code>security-assessment-2026-07.md</code>
AC-12	Implemented	Sessions expire: the gateway session TTL is <code>SessionTtlHours</code> (02); the portal's signed cookie TTL is <code>SessionTtlHours</code> (04); the gateway admin bearer is short-lived and re-checked per call.	<code>cloudformation/02-gateway.yaml</code> (<code>session: ttl_hours</code>); <code>cloudformation/04-download-portal.yaml</code> (<code>SESSION_TTL_HOURS</code>)	<code>conops.md</code> §6.2; <code>client-config.md</code> §5.9
AC-17	Implemented	Remote access is the only access: the ALB is <code>Scheme: internal</code> , reachable through a Zscaler ZPA app segment, and pre-auth reachability is bounded by <code>ClientIngressCidr</code> .	<code>cloudformation/02-gateway.yaml</code> (<code>LoadBalancer</code> , <code>AlbSecurityGroup</code>)	<code>conops.md</code> §4; <code>architecture.md</code> §1, §7
AC-17	Deviation	<code>ClientIngressCidr</code> still defaults to <code>10.0.0.0/8</code> in the template. It must be set per deployment to the ZPA App	<code>cloudformation/02-gateway.yaml</code> (<code>ClientIngressCidr</code>)	

Control	Status	Implementation summary	Where implemented	Where documented
		Connector source range — the same ALB SG now fronts the gateway, / grafana and /portal (including the spend-cap admin page).		conops.md §7; accepted risk A6 in security-assessment-2026-07.md
AC-20	Implemented	Client-side external system use is constrained by the managed catch-all policy: WebFetch , WebSearch and mcp___* are denied as bare tool names, so they are removed from the model's context and cannot be re-allowed at user scope.	cloudformation/02-gateway.yaml (GATEWAY_MANAGED_B64 , cli.permissions.deny)	client-config.md §6; accepted risk A8 (Bash and Agent deliberately not denied)

4. AU — Audit and Accountability

The four audit surfaces and their retention are tabulated once, in monitoring-and-retention.md §3. Rows here point at it rather than restating numbers.

Control	Status	Implementation summary	Where implemented	Where documented
AU-2	Implemented	Five distinct record types are generated: pgaudit statement audit, ALB access logs, portal download/denial/admin audit, the gateway's <code>admin_audit</code> spend-cap trail, and the opt-in AI activity stream. Bedrock prompt logging is a sixth, opt-in and account-wide.	<code>01 (DBParameterGroup pgaudit.log); 02 (AlbLogsBucket, gateway admin: block); 03 (ActivityLogGroup, bedrock-prompts destinations); 04 (/claude/<prefix>/portal-audit)</code>	<code>monitoring-and-retention.md §3; conops.md §5.4</code>
AU-3	Implemented	Portal audit records carry timestamp, verified Okta identity (<code>user_email</code> , <code>user_groups</code>), selections, release version, binary SHA-256, ALB-attested source IP and outcome. <code>admin_audit</code> records the acting principal as <code>oidc:<sub></code> , with the email joined from a portal-maintained <code>sub→email</code> map and from the gateway's own <code>principal_emails</code> table.	<code>docker/portal/portal/audit.py</code> , <code>identity.py</code> ; gateway <code>admin_audit</code> (binary schema)	<code>conops.md §5.4; cost-controls.md §7</code>
AU-3(1)	Deviation	pgaudit runs with <code>pgaudit.log_parameter=0</code> — bind values may carry user content and are deliberately excluded, trading record completeness for data minimization.	<code>cloudformation/01-database.yaml</code> (DBParameterGroup)	<code>monitoring-and-retention.md §3; architecture.md §5</code>
AU-4	Inherited	Storage is CloudWatch Logs and S3; neither imposes an operator-managed capacity ceiling. Retention, not capacity, is the managed dimension.	—	<code>monitoring-and-retention.md §3–§4</code>
AU-5	Implemented	Telemetry/audit processing failure stops service by default: the ADOT sidecar is <code>Essential</code> + health-checked and the gateway container waits on it <code>HEALTHY</code> , so the gateway does not serve traffic while telemetry/audit processing is down (<code>TelemetryFailClosed=true</code>). The end-to-end backstop is the <code><prefix>-missing-telemetry</code> alarm.	<code>cloudformation/02-gateway.yaml</code> (sidecar container definition, <code>dependsOn</code> , <code>TelemetryFailClosed</code>); <code>cloudformation/03-observability.yaml</code> (<code>MissingTelemetryAlarm</code>)	<code>conops.md §6.2; monitoring-and-retention.md §1; om-runbooks.md §9</code>
AU-5	Partial	Three audit-failure paths are not covered: portal audit writes fail open and unalarmed (AUD-4); the Firehose→S3 leg carrying the 731-day activity copy is unmonitored (AUD-3); the fail-closed spend store has no RDS alarm (AUD-1). Stacks 01 and 04 define zero alarms.	<code>cloudformation/01-database.yaml</code> , <code>cloudformation/04-download-portal.yaml</code> (no <code>AWS::CloudWatch::Alarm</code> resources)	<code>poam.md</code> (registered as prior AUD-1, AUD-3, AUD-4)
AU-6	Partial	The sensitive streams are flagged for SIEM subscription and diagnostics tooling exists (<code>scripts/diagnostics/</code>), but no review cadence, reviewer role, or SLA is defined anywhere in the repo.	<code>scripts/diagnostics/</code>	<code>gap: ato-package-gaps.md GAP-8</code>
AU-8	Inherited	Record timestamps come from CloudWatch Logs, RDS, and the container runtime; time synchronization is an AWS platform service. Not configured by these templates.	—	—
AU-9	Implemented			

Control	Status	Implementation summary	Where implemented	Where documented
		Audit stores are CMK-encrypted, IAM-only, public-access-blocked and TLS-only; all nine log groups across the four templates carry <code>DeletionPolicy: Retain</code> , so a stack teardown destroys no audit record. Five of the nine additionally carry a load-bearing <code>retention-policy: retain-on-teardown</code> tag, present so that an update touching only the deletion policy is a real property diff rather than a dropped no-op — do not remove it.	<code>01 – 04</code> (all <code>AWS::Logs::LogGroup</code> , <code>ActivityArchiveBucket</code> , prompt-logs bucket)	<code>architecture.md</code> §9; <code>monitoring-and-retention.md</code> §3
AU-9	Deviation	S3 Object Lock is deferred by decision — no WORM retention on the activity archive, the Bedrock prompt-log bucket, or the ALB access-log bucket. A sufficiently privileged principal can delete objects or shorten retention.	— (deliberately absent)	<code>conops.md</code> §7; accepted risk A1 in <code>security-assessment-2026-07.md</code> ; <code>om-runbooks.md</code> §8
AU-9	Deviation	The ALB access-logs bucket is SSE-S3, not the CMK — ELB log delivery does not support KMS. Compensated by public-access block, IAM-only reads and 90-day lifecycle expiry. Do not "fix" it.	<code>cloudformation/02-gateway.yaml</code> (<code>AlbLogsBucket</code>)	<code>architecture.md</code> §9, §10 note 2; accepted risk A5
AU-11	Implemented	Retention is set per surface and tabulated with its parameter name and shipped default — 731 d pgaudit and activity archive, 365 d portal audit and gateway <code>admin_audit</code> , 90 d ALB logs, 150 d AMP (service default, not template-set).	<code>01</code> (<code>PgauditLogRetentionDays</code>); <code>02</code> (<code>AlbLogRetentionDays</code>); <code>03</code> (<code>ActivityLogWindowDays</code> , <code>ActivityArchiveRetentionDays</code>); <code>04</code> (<code>PortalAuditRetentionDays</code>)	<code>monitoring-and-retention.md</code> §3, §5
AU-12	Implemented	Generation is on by default for pgaudit, ALB, portal and spend-cap audit; the AI activity stream is opt-in (<code>FORWARD_ACTIVITY_LOGS</code>) and Bedrock prompt logging is opt-in and tri-state (<code>BEDROCK_PROMPT_LOGGING</code>).	<code>cloudformation/03-observability.yaml</code> ; <code>scripts/deploy-observability.sh</code>	<code>conops.md</code> §5.4; <code>om-runbooks.md</code> §11

5. CA — Assessment, Authorization, and Monitoring

Control	Status	Implementation summary	Where implemented	Where documented
CA-2	Implemented	A point-in-time security assessment of the whole posture exists, with methodology, verification ledger and severity calibration.	—	security-assessment-2026-07.md
CA-5	Implemented	Open findings are tracked as a POA&M with severity, owner, milestone and status.	—	poam.md
CA-7	Partial	Automated monitoring exists (four CloudWatch alarms, Container Insights, diagnostics scripts) but there is no continuous-monitoring <i>strategy</i> : no alarm ownership, no log-review cadence, no reassessment trigger, no access-review cycle.	cloudformation/02 + 03 alarms; scripts/ diagnostics/	monitoring-and-retention.md §1; gap: ato-package-gaps.md GAP-8
CA-3 / CA-9	Partial	External interconnections (Okta, Zscaler, Bedrock/GovCloud) are described operationally but there is no interconnection/shared-responsibility register naming agreements, owners and failure modes.	—	conops.md §8.2; gap: ato-package-gaps.md GAP-10

6. CM — Configuration Management

Control	Status	Implementation summary	Where implemented	Where documented
CM-2	Implemented	The baseline is code: four CloudFormation templates, a <code>deploy.env</code> parameter set (only <code>deploy.env.example</code> is committed), digest-pinned base images persisted as <code>*_BASE_IMAGE</code> , and a pinned Grafana plugin.	<code>cloudformation/01-04</code> ; <code>scripts/deploy.env.example</code> ; <code>scripts/mirror/mirror-base-images.sh</code> ; <code>scripts/mirror/grafana-plugin.pin</code>	<code>greenfield-deployment.md</code> ; <code>om-runbooks.md</code> §6
CM-3	Partial	Change control is enforced by repo rules and CI, not by an org process document: <code>.claude/rules/process.md</code> mandates a multi-agent adversarial self-review of nontrivial CFN/script/Lambda diffs and a green <code>make test</code> before commit; CI runs the same suites. No emergency-change or authorization procedure is written down.	<code>.claude/rules/process.md</code> ; <code>.github/workflows/tests.yml</code> ; <code>Makefile</code>	<code>gap: ato-package-gaps.md</code> GAP-11
CM-5	Implemented	Change is restricted mechanically: ECR repositories are created <code>IMMUTABLE</code> (and back-filled to immutable if they pre-exist), and CloudFormation stack policies applied by the deploy scripts deny <code>Update:Replace</code> / <code>Update>Delete</code> on the ALB and the RDS instance, backed by deletion protection and fixed physical names.	<code>scripts/common.sh</code> (ensure_ecr_repo); <code>scripts/deploy-database.sh</code> and <code>scripts/deploy-gateway.sh</code> (set-stack-policy)	<code>architecture.md</code> §8; <code>.claude/rules/cloudformation.md</code>
CM-6	Implemented	Runtime configuration is rendered from template parameters into <code>/etc/claude/gateway.yaml</code> at container start; client-side configuration is pushed centrally through the gateway's managed-settings policy rather than set per machine.	<code>cloudformation/02-gateway.yaml</code> (config block, <code>GATEWAY_MANAGED_B64</code>); <code>docker/entrypoint.sh</code>	<code>client-config.md</code> §6, §7
CM-7	Implemented	Least functionality across three surfaces: no HTTP:80 listener anywhere; Grafana's local login form disabled and its background plugin preinstaller disabled (<code>GF_PLUGINS_PREINSTALL_DISABLED=true</code>); client web/MCP tools denied in the managed policy.	<code>cloudformation/02-gateway.yaml</code> (listener set); <code>cloudformation/03-observability.yaml</code> (Grafana env)	<code>architecture.md</code> §2; <code>client-config.md</code> §6
CM-8	Partial	Component inventories exist and are maintained by hand — secrets and keys, security groups, encryption at rest — and container bases are digest-pinned. There is no SBOM and no automated component inventory. One mirror script (<code>mirror-collector.sh</code>) still lacks the architecture pin/assert its sibling has (SUP-1).	<code>architecture.md</code> inventories; <code>scripts/mirror/mirror-base-images.sh</code>	<code>architecture.md</code> §6, §7, §9; <code>poam.md</code> (prior SUP-1); <code>gap: ato-package-gaps.md</code> GAP-9

7. CP — Contingency Planning

Control	Status	Implementation summary	Where implemented	Where documented
CP-2	Not met (documentation)	No contingency plan document exists. Operationally, degraded-mode behavior per component <i>is</i> described, and a full rebuild runbook exists — but no declared RTO/RPO, criticality table or DR test record.	—	conops.md §6.2; gap: ato-package-gaps.md GAP-5
CP-6 / CP-7	Deviation	Single-region deployment; there is no alternate storage or processing site. Multi-AZ within us-gov-west-1 is the only redundancy (MultiAZ default true; gateway DesiredCount default 2). Cross-region DR was not implemented.	cloudformation/01-database.yaml (MultiAZ); cloudformation/02-gateway.yaml (DesiredCount)	gap: ato-package-gaps.md GAP-5
CP-9	Implemented	RDS automated backups run at BackupRetentionDays (default 14, max 35) with PITR; DeletionPolicy/UpdateReplacePolicy: Snapshot means a stack delete or replace takes a final snapshot ; the AMP workspace, both S3 archives and every log group are Retain. An on-demand pre-op snapshot command is part of the runbook.	cloudformation/01-database.yaml (Database); 03 (Workspace, ActivityArchiveBucket)	om-runbooks.md §8
CP-10	Partial	Recovery is documented and honest about its cost: because the DB endpoint is a cross-stack export locked while imported, restore is effectively teardown + restore , a maintenance-window operation, not an update. Greenfield redeployment is a separate, complete runbook. No recovery-time objective is declared and no restore has been rehearsed on the record.	cloudformation/01-database.yaml (exports); scripts/deploy-*.sh	om-runbooks.md §8; greenfield-deployment.md; gap: ato-package-gaps.md GAP-5

8. IA — Identification and Authentication

Control	Status	Implementation summary	Where implemented	Where documented
IA-2	Implemented	All three human-facing surfaces authenticate against the same Okta issuer with distinct clients and redirect URIs: gateway (developer sign-in), Grafana (/grafana/login/generic_oauth), portal (/portal/oauth/callback).	cloudformation/02-gateway.yaml (oidc:); 03 (generic_oauth); 04 (OIDC_ISSUER / OIDC_CLIENT_ID)	architecture.md §3; conops.md §5.1
IA-2(1)(2)	Inherited	Multi-factor authentication is an Okta authentication-policy decision at the org tenant; nothing in these templates sets or can verify it.	—	conops.md §8.2
IA-5	Implemented	Authenticator management is inventoried secret by secret with its creator, consumer and rotation mode. The application DB secret rotates automatically (APP_SECRET_ROTATION_DAYS , default 90) using an alternating-user scheme whose finishSecret forces the gateway service to roll; the remaining secrets have documented manual rotation procedures.	cloudformation/02-gateway.yaml (AWS::SecretsManager::RotationSchedule , DbRotationFunction); docker/db-admin/app.py	architecture.md §6; om-runbooks.md §2, §3, §7; cost-controls.md §7
IA-5	Implemented	Secret handling is a coded rule: values never appear on argv (mode-600 file:// temp files via put_secret_and_roll), never in CloudFormation parameters, and each set-* -secret.sh rolls its consuming service.	scripts/common.sh (put_secret_and_roll); scripts/set-okta-secret.sh , set-grafana-oidc-secret.sh , set-portal-oidc-secret.sh	architecture.md §6; .claude/rules/security.md
IA-5(7)	Implemented	No static authenticator is embedded in the client rollout or in an image: the per-task TLS material is generated at image build and never leaves the task, and Postgres credentials arrive only as ECS secret injection at launch.	docker/entrypoint.sh ; cloudformation/02-gateway.yaml (task definition Secrets)	architecture.md §6
IA-6	Implemented	The portal admin flow deliberately avoids a shared credential: it drives the gateway's OAuth device flow (RFC 8628) so each admin acts as themselves, the gateway re-checks the token's groups claim per call, and admin_audit records the individual rather than a key id.	docker/portal/portal/gateway.py , views/admin.py ; cloudformation/02-gateway.yaml (admin_groups ← SpendAdminGroups)	cost-controls.md §2.1, §7; accepted risk A11
IA-8	Not applicable	There are no non-organizational users; every surface requires the org's own Okta tenant.	—	conops.md §3
SC-23 / IA (session integrity)	Implemented	Portal OIDC is a full authorization-code flow with state , PKCE (S256) and nonce ; ID-token verification hard-pins RS256, filters JWKS keys, and uses constant-	docker/portal/portal/crypto.py , oidc.py , views/auth.py	security-assessment-2026-07.md (verified strengths)

Control	Status	Implementation summary	Where implemented	Where documented
		time comparison. Session cookies are HMAC-signed, HttpOnly , Secure , SameSite=Lax .		

9. SC — System and Communications Protection

Control	Status	Implementation summary	Where implemented	Where documented
SC-7	Implemented	The boundary is an internal ALB in a no-NAT spoke VPC, with AWS API traffic pinned to interface/gateway VPC endpoints and every workload SG carrying explicit egress.	<code>cloudformation/02-gateway.yaml</code> (<code>LoadBalancer</code> , all <code>AWS::EC2::VPC::VPCEndpoint</code>); <code>03/04</code> cross-stack SG rules	<code>architecture.md</code> §1, §7; <code>network-access-controls.md</code> §1–§3
SC-7(4)	Implemented	Every VPC interface endpoint carries a resource policy scoped to this account/workload — the <code>bedrock-runtime</code> endpoint to exactly the three configured model IDs and their profiles, <code>secretsmanager</code> to this deployment's secret ARNs, <code>aps-workspaces</code> to this workspace.	<code>cloudformation/02-gateway.yaml</code> (<code>BedrockRuntimeEndpoint</code> , <code>SecretsManagerEndpoint</code>); <code>cloudformation/03-observability.yaml</code> (<code>AmpEndpoint</code>)	<code>network-access-controls.md</code> §3
SC-7(4)	Deviation	The <code>ecs</code> interface endpoint carries no endpoint policy: GovCloud does not support one on that service and attaching a <code>PolicyDocument</code> fails the stack. IAM-side scoping compensates.	<code>cloudformation/02-gateway.yaml</code> (<code>EcsEndpoint</code>)	<code>network-access-controls.md</code> (accepted risks, up front); accepted risk A7
SC-7(5)	Implemented	Deny-by-default: default egress is suppressed on every security group (a <code>127.0.0.1/32</code> placeholder replaces the implicit allow-all), and a <code>cfn-guard</code> CI rule fails any template that omits explicit egress.	<code>01–04</code> security groups; <code>tests/cfn</code> (<code>cfn-guard</code> ruleset)	<code>network-access-controls.md</code> §1; <code>architecture.md</code> §7
SC-8 / SC-8(1)	Implemented	No plaintext hop exists. There is no HTTP:80 listener; the ALB re-encrypts to per-task TLS on all three targets, each target group with an explicit <code>HealthCheckProtocol: HTTPS</code> (CI-gated); RDS is <code>sslmode=verify-full</code> with <code>rds.force_ssl=1</code> server-side; Bedrock, AMP and Okta legs are TLS.	<code>cloudformation/02-gateway.yaml</code> (<code>HttpsListener</code> , <code>TargetGroup</code>); <code>cloudformation/01-database.yaml</code> (<code>DBParameterGroup</code>); <code>docker/entrypoint.sh</code>	<code>architecture.md</code> §2 (per-hop table)
SC-8	Implemented	The telemetry leg satisfies SC-8 by absence of transmission : the ADOT collector runs as a localhost sidecar inside the gateway task with its OTLP receivers on <code>127.0.0.1</code> and no port mappings, so no network hop exists to encrypt. This required <code>CLAUDE_GATEWAY_ALLOW_LOOPBACK=1</code> (gated on telemetry being enabled; re-permits only loopback/unspecified, leaving IMDS and link-local blocked).	<code>cloudformation/02-gateway.yaml</code> (sidecar container, <code>CLAUDE_GATEWAY_ALLOW_LOOPBACK</code>)	<code>architecture.md</code> §10 note 1; <code>conops.md</code> §7; accepted risk A2 (supersedes the earlier plaintext-hop acceptance)
SC-12 / SC-17	Implemented	One customer-managed KMS key (<code>alias/<prefix></code> , <code>EnableKeyRotation: true</code>) plus an ACM-imported enterprise leaf for the ALB. A self-managed application CA was considered and rejected to avoid an SC-17 shadow-PKI and SC-12 key-custody burden; per-task certs are ephemeral and never leave the task.	<code>cloudformation/01-database.yaml</code> (<code>KmsKey</code> , <code>KmsKeyAlias</code>); <code>scripts/import-enterprise-cert.sh</code>	<code>architecture.md</code> §6; <code>om-runbooks.md</code> §1; accepted risk A2
SC-13	Partial	The ALB listener defaults to a FIPS TLS policy (<code>ELBSecurityPolicy-TLS13-1-2-FIPS-2023-04</code> , parameter <code>TlsSecurityPolicy</code>) and KMS provides FIPS-validated key	<code>cloudformation/02-gateway.yaml</code> (<code>TlsSecurityPolicy</code>)	<code>fips-199-categorization.md</code> §7;

Control	Status	Implementation summary	Where implemented	Where documented
		operations. The repo configures no AWS FIPS service endpoints, and the crypto modules behind the internal TLS legs are unverified.		gap: ato-package-gaps.md GAP-14
SC-28	Implemented	Everything at rest uses the single customer-managed CMK — RDS storage and snapshots, all Secrets Manager secrets, every CloudWatch log group (template-declared precisely so the CMK and retention apply), the activity and prompt-log archives, the portal artifacts bucket, AMP (creation-time ENCRYPT_AMP_WITH_CMK), and ECR at creation.	01–04 ; scripts/common.sh (ensure_ecr_repo CMK encryption)	architecture.md §9
SC-28	Deviation	One exception: the ALB access-logs bucket (SSE-S3). See AU-9 above.	cloudformation/02-gateway.yaml (AlbLogsBucket)	architecture.md §9; accepted risk A5

10. SI — System and Information Integrity

Control	Status	Implementation summary	Where implemented	Where documented
SI-2	Partial	ECR repositories are created with <code>scanOnPush=true</code> ; image and stack updates have a full runbook; a minimum client-version floor (<code>requiredMinimumVersion</code> , parameter <code>MinClientVersion</code> , defaulting to the gateway's own version) keeps the fleet off stale clients. Missing: severity→remediation-window SLA, how <code>claude</code> binary CVEs are learned given locked auto-updates, SBOM, pen-test scope.	<code>scripts/common.sh</code> (<code>ensure_ecr_repo</code>); <code>cloudformation/02-gateway.yaml</code> (<code>MinClientVersion</code>)	<code>om-runbooks.md</code> §5, §6; <code>client-config.md</code> §5.8, §6; gap: <code>ato-package-gaps.md</code> GAP-9
SI-3	Inherited	Endpoint malicious-code protection is the managed-laptop build's; nothing in this system scans content.	—	<code>conops.md</code> §8.2
SI-4	Partial	Four CloudWatch alarms exist (<code><prefix>-certificate-expiry</code> , <code>-db-rotation-errors</code> , <code>-missing-telemetry</code> , <code>-missing-activity-logs</code>), plus Container Insights and a diagnostics toolkit. Coverage gaps are known and tracked: no RDS alarms (AUD-1), no <code>failed_translations</code> detection (AUD-2), unmonitored Firehose leg (AUD-3), no ALB/ECS availability alarms (AUD-5).	<code>cloudformation/02-gateway.yaml</code> , <code>03-observability.yaml</code> (<code>AWS::CloudWatch::Alarm</code>); <code>scripts/diagnostics/</code>	<code>monitoring-and-retention.md</code> §1; <code>om-runbooks.md</code> §9, §9a; <code>poam.md</code>
SI-4	Deviation	The <code><prefix>-missing-telemetry</code> alarm detects total cessation, not degradation — <code>Average ≤ 0</code> resets on any non-zero minute, and its heartbeat is the collector's own self-metrics, which keep flowing even if 100% of client metrics are dropped. It is a floor, not a coverage guarantee.	<code>cloudformation/03-observability.yaml</code> (<code>MissingTelemetryAlarm</code>)	accepted risk A16; <code>poam.md</code> (prior AUD-2)
SI-5	Partial	Alarm notification is an organizational prerequisite, not a system capability: the stacks create no SNS topic and accept one optional <code>ALARM_SNS_TOPIC_ARN</code> . If it is empty the alarms still show state but nobody is told.	<code>cloudformation/02-gateway.yaml</code> , <code>03-observability.yaml</code> (<code>AlarmSnsTopicArn</code>)	<code>monitoring-and-retention.md</code> §2; gap: <code>ato-package-gaps.md</code> GAP-8 and the org dependency block
SI-7	Implemented	Software integrity is verified at every hop into the boundary: the release mirror GPG-verifies the manifest and fails closed unless <code>ALLOW_UNVERIFIED_MANIFEST=1</code> is set explicitly; every mirrored artifact is SHA-256-checked on consumption (<code>require_mirrored_file</code> , <code>verify_sha256</code>); base images are digest-pinned; ECR tags are immutable; the Windows and Linux installers verify the binary's SHA-256 from a staged copy before installing.	<code>scripts/mirror/mirror-claude-release.sh</code> ; <code>scripts/common.sh</code> ; <code>scripts/mirror/mirror-base-images.sh</code> ; <code>client/InstallClaudeCode.ps1</code> , <code>client/install-claude-code.sh</code>	<code>conops.md</code> §5.1; <code>.claude/rules/offline-build.md</code> ; <code>.claude/rules/security.md</code>
SI-10	Implemented	Operator-supplied and user-supplied inputs are validated server-side: the portal validates the cost-center/team pair and the platform selection regardless of what the form posted, and a malformed cost-	<code>docker/portal/portal/selection.py</code> , <code>money.py</code> , <code>config.py</code>	<code>cost-controls.md</code> §2.1; <code>security-assessment-2026-07.md</code>

Control	Status	Implementation summary	Where implemented	Where documented
		center→teams mapping fails the task at boot. Money is exact integer-cents arithmetic with strict format validation.		
SI-12	Implemented	Handling and retention for every record type — destination, retention, encryption, sensitivity flag — is tabulated in one place, with parameter names and shipped defaults.	01 – 04 retention parameters	monitoring-and-retention.md §3–§5

11. SA / SR — Acquisition and Supply Chain

Control	Status	Implementation summary	Where implemented	Where documented
SA-10	Implemented	Developer configuration management is the repository: infrastructure is entirely declarative, parameters are externalized to <code>deploy.env</code> , and deploy scripts persist their outputs back so there are no copy-paste steps between stages.	<code>cloudformation/</code> ; <code>scripts/common.sh</code> (<code>set_env_var</code>)	<code>greenfield-deployment.md</code> ; <code>conops.md</code> §5.5
SA-11	Implemented	Developer testing is enforced, not optional: five suites (<code>tests/lambda</code> , <code>tests/portal</code> , <code>tests/bash</code> , <code>tests/cfn</code> , <code>tests/powershell</code>) run under <code>make test</code> and in CI, and <code>tests/cfn/rules.guard</code> encodes the hard rules as gates — CMK on log groups and secrets, log groups surviving teardown, explicit SG egress, HTTPS health-check protocol on HTTPS target groups, RDS CMK storage, S3 public-access block, and the ALB staying internal/IPv4-only.	<code>Makefile</code> ; <code>tests/cfn/rules.guard</code> ; <code>.github/workflows/tests.yml</code>	<code>.claude/rules/process.md</code>
SA-22	Partial	Component versions are pinned and updated deliberately through a documented runbook (base images, Grafana, the ADOT collector, the <code>claude</code> client). No formal supported-version policy or end-of-support tracking exists.	<code>scripts/mirror/mirror-base-images.sh</code> ; <code>scripts/mirror/grafana-plugin.pin</code>	<code>om-runbooks.md</code> §5, §6; gap: <code>ato-package-gaps.md</code> GAP-9
SR-3	Implemented	A hard architectural separation implements supply-chain control: the build/deploy host reaches only AWS service endpoints, all external artifacts flow through <code>scripts/mirror/*.sh</code> on a separate egress host, and build scripts <i>consume</i> the transferred mirror — failing closed with instructions naming the exact mirror script rather than fetching. No Dockerfile fetches anything at build time; Python dependencies install <code>--no-index</code> from committed, exact-pinned wheels.	<code>scripts/mirror/</code> ; <code>scripts/common.sh</code> (<code>require_mirrored_file</code>); <code>docker/*/Dockerfile</code>	<code>.claude/rules/offline-build.md</code> ; <code>om-runbooks.md</code> §4, §5, §6
SR-4	Implemented	Provenance is recorded per artifact: GPG-verified release manifest, SHA-256 pins for the Grafana plugin (<code>grafana-plugin.pin</code>) and the RDS CA bundle, digest-pinned base images persisted into <code>deploy.env</code> .	<code>scripts/mirror/mirror-claude-release.sh</code> , <code>mirror-grafana-plugin.sh</code> , <code>mirror-rds-ca-bundle.sh</code> , <code>mirror-base-images.sh</code>	<code>om-runbooks.md</code> §4, §5, §6
SR-11	Partial	Authenticity checks are consistent except in two places tracked as findings: <code>mirror-collector.sh</code> lacks the <code>--platform</code> pin and post-pull architecture assert its sibling has (SUP-1), and vendored wheels are installed without <code>--require-hashes</code> , so transitive versions are pinned only by which file sits in <code>vendor/</code> .	<code>scripts/mirror/mirror-collector.sh</code> , <code>mirror-python-deps.sh</code>	<code>poam.md</code> (prior SUP-1; the wheel-hash item)

12. Families not addressed by this repository

These families are **out of scope for the code** and belong to the deploying organization or to documentation that does not yet exist. They are listed so a reviewer sees the absence deliberately rather than discovering it.

Family	Why it is not here	Where it is tracked
AT — Awareness and Training	Security and role-based training, including AI-usage training, is an organizational program.	org dependency block, <code>ato-package-gaps.md</code>
PS — Personnel Security	Screening, agreements, transfer/termination actions are organizational.	org dependency block, <code>ato-package-gaps.md</code>
PE — Physical and Environmental	Fully inherited from AWS GovCloud and the org's facilities.	§2 above
IR — Incident Response	No incident-response plan exists; containment primitives do (Okta group removal, <code>desired-count 0</code> , ALB rule removal, key rotation, spend clamp) but are not assembled into a procedure.	<code>ato-package-gaps.md</code> GAP-4
MP — Media Protection	Teardown retains log groups, both S3 archives, a final RDS snapshot, ECR images and the AMP workspace; no sanitization/destruction procedure or authorization step is written.	<code>ato-package-gaps.md</code> GAP-15; <code>om-runbooks.md</code> §13
PL — Planning	No system security plan narrative, rules of behavior, or architecture-change planning document.	<code>ato-package-gaps.md</code> GAP-7
RA — Risk Assessment	Vulnerability scanning posture is partly implemented (ECR <code>scanOnPush</code>) but undocumented; no risk-assessment document.	<code>ato-package-gaps.md</code> GAP-9
PT — PII Processing and Transparency	Identity attributes, per-user usage attribution and (when enabled) command/prompt content are processed; no privacy threshold analysis exists.	<code>ato-package-gaps.md</code> GAP-6

13. Deviations and accepted risks, collected

Surfaced here in one place so a reviewer does not have to find them in the rows. Full rationale, compensating controls and alternatives-considered are in `security-assessment-2026-07.md` §2; the identifiers below are that document's.

Ref	Deviation	Controls touched	Row
A1	S3 Object Lock deferred — no WORM on any audit archive	AU-9, AU-11	§4
A2	Telemetry SC-8 met by absence of transmission (loopback sidecar), not encryption; requires <code>CLAUDE_GATEWAY_ALLOW_LOOPBACK=1</code> . Reverses the earlier "plaintext-but-SG-scoped" acceptance, which was withdrawn as unimplementable	SC-8, SC-12, SC-17	§9
A3	Spend enforcement fails closed — a spend-store outage halts inference fleet-wide	AU-5, availability	<code>cost-controls.md</code> §5
A4	Bedrock prompt logging, when enabled, is account- and region-wide and has no per-user attribution	AU-2, AU-3	§4
A5	ALB access-logs bucket is SSE-S3, not the CMK (ELB platform limitation)	SC-28, AU-9	§4, §9
A6	<code>ClientIngressCidr</code> template default is <code>10.0.0.0/8</code> and must be tightened per deployment	AC-17, SC-7	§3
A7	<code>ecs</code> interface endpoint carries no endpoint policy (unsupported in GovCloud)	SC-7(4)	§9
A8	Client-side <code>Bash</code> (<code>curl/wget</code>) and <code>Agent</code> subagents are deliberately not denied	AC-20, CM-7	§3
A9	Group changes take effect only at session/token expiry — TTL is the deprovisioning bound	AC-2(3)	§3
A10	The portal task holds the read-only spend key	AC-6(1)	§3
A15	Gateway access control is email-domain-based; Okta groups are not gateway authorization	AC-3	§3
A16	<code>TelemetryFailClosed</code> is an availability trade; the missing-telemetry alarm detects cessation, not degradation	AU-5, SI-4	§4, §10

Maintenance: update a row in the same change that alters the resource it cites. If a control's status changes because a finding closed, update `poam.md` in the same change. New documentation gaps go to `ato-package-gaps.md`, not here.